

EVALUACIÓN DE VULNERABILIDADES

Uso del modelo CVSS v3.1

Integrantes:

Aguilar Carrizales Miguel Ángel – 182318
Aznar Cuevas Luis Eduardo – 179880
Beltrán Reyna David – 183636
Gómez Arreguín Donaldo Demián – 179822
Morales Hernández Roberto Emiliano – 182377
Rosales Ramírez Josué Emiliano – 181760

Materia:

CNO V: Seguridad Informática

Profesor:

López, Servando

Grupo:

T46A

Contenido

Evaluación de Vulnerabilidades con CVSS v3.1.....	3
Resumen Ejecutivo.....	3
Objetivos.....	3
Objetivo General.....	3
Objetivos Específicos.....	3
Descripción del escenario.....	3
Identificación de métricas CVSS v3.1.....	4
Construcción del vector CVSS.....	5
Interpretación técnica.....	6
A) ¿Por qué, a pesar de requerir privilegios elevados, la vulnerabilidad sigue siendo relevante?.....	6
B) ¿Qué tipo de atacante podría explotarla?.....	6
C) ¿Qué significa que el impacto sea bajo en las tres dimensiones?.....	6
Cálculo de puntuación CVSS.....	6
Vector utilizado.....	6
Resultado obtenido.....	7
Interpretación del resultado.....	7
Importancia de la priorización de vulnerabilidades.....	7
Conclusiones.....	8
Bibliografía.....	8

Evaluación de Vulnerabilidades con CVSS v3.1

Resumen Ejecutivo

La presente actividad tiene como propósito aplicar el **modelo CVSS v3.1** (*Common Vulnerability Scoring System*) para evaluar la gravedad de una vulnerabilidad detectada en un sistema web interno.

A partir del escenario proporcionado, se identifican las métricas base correspondientes, se construye correctamente el **vector CVSS** y se obtiene una puntuación de riesgo utilizando la calculadora oficial de **FIRST**.

Asimismo, se realiza un análisis técnico orientado a interpretar el impacto de la vulnerabilidad dentro de un contexto organizacional, considerando factores como privilegios requeridos, complejidad de explotación y efectos sobre la confidencialidad, integridad y disponibilidad.

Objetivos

Objetivo General

Aplicar el modelo CVSS v3.1 para evaluar la **gravedad** de una vulnerabilidad informática, interpretando correctamente sus métricas base y justificando la priorización del riesgo dentro de un entorno organizacional.

Objetivos Específicos

- Identificar correctamente las métricas base del modelo CVSS v3.1.
- Construir una cadena vector CVSS a partir de un escenario técnico.
- Utilizar la calculadora oficial de FIRST para obtener la puntuación base.
- Interpretar técnicamente el nivel de riesgo asociado a la vulnerabilidad.
- Comprender la importancia de la priorización de vulnerabilidades en ciberseguridad.

Descripción del escenario

Una organización detecta una vulnerabilidad en un sistema web interno con las siguientes características:

1. Puede explotarse a través de la red.
2. La explotación requiere baja complejidad.
3. Se necesitan privilegios elevados.
4. No requiere interacción del usuario.

5. No cambia el alcance.
6. El impacto en:
 - a. **Confidencialidad:** Bajo.
 - b. **Integridad:** Bajo.
 - c. **Disponibilidad:** Bajo.

Identificación de métricas CVSS v3.1

A partir del escenario proporcionado, se identificaron las siguientes métricas base:

Métrica	Valor	Justificación
Attack Vector (AV)	Network (N)	La vulnerabilidad puede explotarse a través de la red.
Attack Complexity (AC)	Low (L)	No existen condiciones especiales complejas para la explotación.
Privileges Required (PR)	High (H)	Se requieren privilegios elevados para ejecutar el ataque.
User Interaction (UI)	None (N)	El usuario no necesita realizar ninguna acción.
Scope (S)	Unchanged (U)	La vulnerabilidad no cambia el alcance de seguridad.
Confidentiality (C)	Low (L)	El impacto sobre la confidencialidad es limitado.
Integrity (I)	Low (L)	Existe una afectación limitada sobre la integridad.
Availability (A)	Low (L)	El impacto sobre la disponibilidad es bajo.

Construcción del vector CVSS

Uso de la calculadora proporcionada por el sitio de *first.org*
(<https://www.first.org/cvss/calculator/3.1>)

The screenshot shows the CVSS 3.1 calculator interface. The Base Score is 4.7 (Medium). The selected metrics are: Attack Vector (AV): Network (N), Attack Complexity (AC): Low (L), Privileges Required (PR): High (H), User Interaction (UI): None (N), Scope (S): Unchanged (U), Confidentiality (C): Low (L), Integrity (I): Low (L), and Availability (A): Low (L).

Imagen 1.1. Inserción de los valores en las métricas de CVSS V3.1

Con base en las métricas identificadas, la cadena vector correspondiente es la siguiente:

Vector String -
CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Imagen 1.2. Cadena vector resultante de las métricas evaluadas

Desglose técnico del vector

Elemento	Significado
AV:N	Ataque remoto a través de la red
AC:L	Baja complejidad de explotación
PR:H	Requiere privilegios elevados
UI:N	No requiere interacción del usuario
S:U	El alcance permanece sin cambios
C:L	Impacto bajo en confidencialidad
I:L	Impacto bajo en integridad
A:L	Impacto bajo en disponibilidad

Interpretación técnica

A) ¿Por qué, a pesar de requerir privilegios elevados, la vulnerabilidad sigue siendo relevante?

La vulnerabilidad continúa siendo relevante debido a que un atacante con acceso privilegiado podría aprovecharla para comprometer parcialmente la seguridad del sistema.

Aunque el requisito de privilegios elevados reduce la probabilidad de explotación por parte de atacantes externos no autenticados, sigue representando un riesgo importante ante amenazas internas, cuentas comprometidas o escalación previa de privilegios.

Además, el hecho de que pueda explotarse remotamente y con baja complejidad incrementa su peligrosidad dentro de entornos corporativos.

B) ¿Qué tipo de atacante podría explotarla?

La vulnerabilidad podría ser explotada por:

- Administradores maliciosos.
- Usuarios internos con altos privilegios.
- Atacantes que previamente comprometieron credenciales administrativas.
- Amenazas persistentes avanzadas (APT) con acceso interno.

Este tipo de escenarios son comunes en ataques de *insider threat* o movimientos laterales dentro de redes corporativas.

C) ¿Qué significa que el impacto sea bajo en las tres dimensiones?

Significa que la vulnerabilidad produce afectaciones limitadas sobre:

- **Confidencialidad:** La exposición de información es parcial o reducida.
- **Integridad:** Las modificaciones sobre datos o procesos son limitadas.
- **Disponibilidad:** La interrupción del servicio no es total ni crítica.

Aunque el impacto individual es bajo, la vulnerabilidad no debe ignorarse, ya que podría combinarse con otras debilidades para generar ataques de mayor severidad.

Cálculo de puntuación CVSS

La puntuación fue obtenida utilizando la calculadora oficial de FIRST para CVSS v3.1.

Vector utilizado

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Resultado obtenido

Elemento	Resultado
Base Score	4.7
Severidad	Media

Interpretación del resultado

La vulnerabilidad se clasifica dentro de la categoría de severidad media debido a que:

- Puede explotarse remotamente.
- La complejidad de ataque es baja.
- No requiere interacción del usuario.
- El impacto general es limitado.
- Requiere privilegios elevados, lo cual reduce parcialmente el riesgo.

El resultado indica que la vulnerabilidad debe atenderse y mitigarse, especialmente en entornos corporativos donde existan múltiples usuarios privilegiados o riesgos de compromiso interno.

Importancia de la priorización de vulnerabilidades

La utilización del modelo CVSS permite a las organizaciones evaluar vulnerabilidades de manera estandarizada, facilitando la toma de decisiones relacionadas con gestión de riesgos y priorización de remediaciones.

Algunas ventajas de utilizar CVSS incluyen:

- Estandarización internacional de vulnerabilidades.
- Priorización objetiva de riesgos.
- Mejora en la gestión de incidentes.
- Optimización de recursos de mitigación.
- Mayor comprensión técnica del impacto.

Asimismo, la correcta interpretación de métricas como privilegios requeridos, complejidad de ataque e impacto permite comprender el contexto real de una amenaza y evitar subestimar vulnerabilidades aparentemente menores.

Dentro de entornos organizacionales, el análisis CVSS ayuda a definir:

- Prioridades de parchado.

- Controles compensatorios.
- Planes de respuesta.
- Estrategias de hardening.
- Gestión de riesgos corporativos.

Conclusiones

A partir del escenario planteado, fue posible identificar correctamente las métricas base, construir el vector CVSS correspondiente y obtener una puntuación de riesgo utilizando la calculadora oficial.

El análisis demuestra que incluso vulnerabilidades con impactos bajos pueden representar riesgos relevantes cuando existen condiciones favorables como explotación remota, baja complejidad o accesos privilegiados comprometidos.

Asimismo, se concluye que el modelo CVSS constituye una herramienta fundamental dentro de los procesos de gestión de vulnerabilidades, ya que facilita la priorización de acciones de mitigación y fortalece la toma de decisiones en ciberseguridad.

Bibliografía

- FIRST. (s. f.). Common Vulnerability Scoring System v3.1 Calculator.
<https://www.first.org/cvss/calculator/3.1> (first.org)
- FIRST. (2019). Common Vulnerability Scoring System Version 3.1: Specification Document.
<https://www.first.org/cvss/v3-1/specification-document> (first.org)
- Mell, P., Scarfone, K., & Romanosky, S. (2007). A Complete Guide to the Common Vulnerability Scoring System Version 2.0. FIRST.org.
- Scarfone, K., & Mell, P. (2009). Guide to the Vulnerability Management Process. National Institute of Standards and Technology (NIST).
- Stallings, W., & Brown, L. (2018). Computer Security: Principles and Practice (4th ed.). Pearson.
- Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.). Cengage Learning.